MAKİNE GÜVENLİĞİ / OT SİBER GÜVENLİK

Biesse Rover A 1632 Smart

İlk dört hafta için güvenlik mimarisi incelemesi

Makine	5 eksen CNC ahşap işleme merkezi
Çalışma türü	Kamuya açık kaynaklara dayalı masa başı değerlendirme
İçerik	Kapsam, varlıklar, risk matrisi ve uzaktan erişim

İnceleme ilkesi: Üreticiyle veya üye firmalarla iletişime geçilmemiştir. Gerçek kurulumda doğrulanmayan ağ ve makine konfigürasyonu bilgileri mevcut durum gibi sunulmamış; açık soru veya öneri olarak işaretlenmiştir.

Paylaşılan çalışma kâğıdındaki Lab 3 risk matrisi ve Lab 4 uzaktan erişim çalışması, seçilen makineye uyarlanmıştır.

HAFTA 1

Kapsam ve yöntem

Amaç, makineyi ve incelenebilecek kanıt sınırını netleştirmektir.

Seçilen makine: Biesse Rover A 1632 Smart, proje kapsamında 5 eksen CNC ahşap işleme merkezi. Temel kaynak, Biesse imzalı Rover A 1632 Smart NC processing centre kullanım kılavuzunun 5801A0572 kodlu, Temmuz 2016 tarihli revizyon 0 kamuya açık kopyasıdır.

Konfigürasyon notu: Kılavuz makine ailesi hakkında bilgi verir. Belirli kurulumun seri numarası, opsiyonları, yazılımı ve 5 eksen donanımı bu kaynakla doğrulanmış sayılmaz.

İnceleme sınırı

DAHİL	HARİÇ
Operatör ve bakım personelinin makine çevresindeki işleri	Fabrikanın gerçek kurumsal ve OT ağı
Malzeme yükleme/boşaltma ve işleme hareketleri	Belirli makinenin IP adresi, portu, hesabı ve uzak servis yazılımı
Kılavuzda anlatılan fiziksel koruyucular ve durdurmalar	Saha testi, kaynak kodu, loglar ve üretim ağına erişim
Uzak destek için hedef güvenlik gereksinimleri	Seri numaralı makine için uygunluk kararı veya belgelendirme

Yöntem

01	Makineyi ve kaynak sınırını tanımla.
02	Fiziksel, dijital ve güvenlikle ilgili varlıkları çıkar.
03	Tehditleri L x S x E matrisiyle önceliklendir.
04	Uzak erişim gereksinimlerini yaz; emniyet işlevlerinin bağımsızlığını değerlendir.
05	Bulguları kaynaklara bağla; bilinmeyen kurulumu gerçekmiş gibi anlatma.

Kanıt etiketleri: Belgede doğrulandı = kaynakta açıkça yer alır. Analiz = kaynaklardan türetilen yorum. Varsayım = gerçek kurulumda doğrulanmamış kabul. Öneri = hedef tasarım gereksinimi. Açık soru = kaynakların yanıtlamadığı bilgi.

HAFTA 2

Varlıklar ve güven sınırları

Kılavuzda doğrulanan makine öğeleri, analizde modellenen varlıklardan ayrılmıştır.

ID	VARLIK	DURUM VE ÖNEM
A01	NC kontrolü ve operatör paneli	Kontrol kılavuzda anlatılır; donanım ve sürüm bilinmiyor.
A02	İş programları ve parametreler	Analiz varlığı; saklama yeri bilinmiyor. Değişiklik hatalı hareket doğurabilir.
A03	Eksenler, işleme kafası ve takım	İşleme hareketi belgelenir; tehlikeli hareketli parçalar bulunur.
A04	İşleme alanı ve çalışma masası	Kılavuz çalışma ve tehlike alanlarını tanımlar.
A05	Koruyucu çit/kapı ve kilitleme anahtarı	Kılavuzda belgelenmiştir; tehlikeli alana erişimi sınırlar.
A06	Temas matı	Kılavuzda belgelenmiştir; giriş algılandığında durdurma işlevi anlatılır.
A07	Acil durdurma ve reset	Kılavuzda belgelenmiştir; reset ve programı yeniden başlatma ayrıdır.
A08	Hareketli bölüm koruması ve perdeler	Temas ve fırlayan talaş risklerini azaltmaya yardımcı olur.
A09	Basınçlı hava kesme vanası	Artık basınç veya yerçekimi riski kalabileceği kılavuzda belirtilir.
A10	Operatör ve bakım personeli	Analiz varlığı; yetki, eğitim ve çalışma yöntemi önemlidir.
A11	Uzak servis oturumu	Mevcut olduğu doğrulanmadı; yalnızca hedef tasarımda koşullu ele alınır.

Sınırların özeti

SINIR	BİLİNEN	BİLİNMEYEN
Fiziksel	Çit/kapı ve matın koruyucu işlevleri anlatılır.	Sensör modeli, yerleşim ve test kayıtları.
Kontrol	NC kontrolü ile işleme hareketi makine işlevinin parçasıdır.	Kontrol mimarisi, kullanıcı rolleri ve ağ topolojisi.
Dış ağ	Kılavuzda uzak servis topolojisi doğrulanmıyor.	Makinenin ofis ağına veya internete bağlı olup olmadığı.

HAFTA 3

Tehdit ve risk matrisi

Lab 3 yaklaşımı korunmuştur. Puanlar ilk masa başı tahminidir, sahada ölçülmüş olasılık değildir.

L x S x E	SEVİYE	YAKLAŞIM
18-27	**Kritik**	Acil önceliklendirme
9-17	**Yüksek**	Öncelikli azaltım
4-8	**Orta**	Planlı azaltım
1-3	**Düşük**	İzle ve yeniden değerlendir

L = olasılık, S = şiddet, E = maruziyet. S=3 olan senaryolar toplam puan düşük olsa bile ayrıca önceliklendirilir.

R01 | Yetkisiz iş programı veya parametre değişikliği — 12 / YÜKSEK

Puan: L=2, S=3, E=2. Hatalı takım yolu veya beklenmeyen hareket iş parçasını/takımı fırlatabilir ve operatörü yaralayabilir. Sınır: Dijital erişim yolu kurulumda doğrulanmadı. Azaltımlar: Bireysel hesap, en az yetki, değişiklik onayı, yedek ve üretim öncesi güvenli doğrulama.

R02 | Tehlike alanına giriş ve koruyucunun etkisiz kalması — 6 / ORTA*

Puan: L=1, S=3, E=2. Çit/kapı veya temas matı etkisiz kalırsa kişi hareketli alana girebilir. Kanıt: Kılavuz bu koruyucuları anlatır; test kayıtları bilinmiyor. Azaltımlar: Kullanım öncesi kontrol, arızada durdurma ve periyodik işlev testi.

R03 | Panel yükleme/boşaltmada kayma veya düşme — 8 / ORTA

Puan: L=2, S=2, E=2. Panel kayması el/ayak yaralanmasına yol açabilir. Kılavuz elle veya yardımcı cihazla yüklemeden söz eder; gerçek ağırlık ve kaldırma yöntemi bilinmiyor. Azaltımlar: Uygun kaldırma yardımcısı, yük sabitleme ve eğitim.

* S=3 önceliği: R02 toplam puanı orta olsa da olası sonucu ağır olduğu için öncelikli doğrulanmalıdır. Puanlar saha incelemesi sonrası yeniden hesaplanmalıdır.

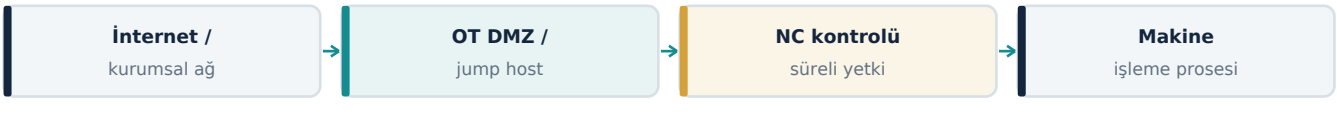
HAFTA 4

Güvenli uzaktan erişim

Aşağıdaki akış mevcut Biesse mimarisinin tarifi değildir; uzak servis gerekiyorsa uygulanacak hedef modeldir.

Amaç: İnternetten NC kontrolüne doğrudan erişimi engellemek ve uzaktan erişim ele geçirilse bile emniyet işlevlerini korumak.

Önerilen hedef akış



Şema hedef mimari önerisidir; mevcut ağ bağlantısının kanıtı değildir.

Asgari gereksinimler

ID	HEDEF	DOĞRULAMA KANITI
RA-01	Erişim varsayılan kapalı; iş emri ve zaman aralığıyla açılır.	İş emri / bağlantı kaydı
RA-02	VPN + MFA ve kullanıcı başına ayrı hesap.	Erişim politikası
RA-03	Doğrudan internet erişimi yok; OT DMZ geçişi kullanılır.	Yetkili ağ şeması
RA-04	En az yetki; ortak/varsayılan hesaplar kapatılır.	Hesap ve rol listesi
RA-05	Kullanıcı, onay, hedef, süre ve değişiklikler kaydedilir.	Oturum kayıtları
RA-06	Program değişikliği yedeklenir ve yerel doğrulamadan geçer.	Değişiklik formu
RA-07	Uzak erişim emniyet işlevlerini devre dışı bırakamaz.	Mimari inceleme/test
RA-08	İş bitince oturum ve geçici yetki kapatılır.	Kapanış kaydı

Bağımsızlık şartı: Emniyet işlevleri internet, VPN veya jump host bağlantısına bağlı olmamalı. Reset, üretim programını kendiliğinden başlatmamalı. Kılavuz reset ile programı yeniden başlatmayı ayrı ele alır.

KANIT PAKETI

Kaynaklar ve açık noktalar

Bu rapor, saha testi veya makine uygunluk sertifikasyonu yerine geçmez.

Saldırgan uzaktan erişimi ele geçirirse emniyet işlevi etkilenir mi? Mevcut kurulum için kamuya açık kaynaklardan yanıt verilemez. Hedef tasarımda cevap hayır olmalıdır: uzaktan servis hesabı koruyucu kapı, temas matı veya acil durdurmayı değiştirememelidir. Bu sonuç yalnızca yetkili mimari inceleme ve testle doğrulanabilir.

Açık sorular

01	Makineye gerçekten ağ veya uzak servis bağlantısı kurulmuş mu?
02	NC kontrolünde kullanıcı rolleri ve değişiklik kayıtları bulunuyor mu?
03	Koruyucular hangi sıklıkta test ediliyor ve kayıtları nerede?
04	Tipik panel ağırlığı ve kaldırma yardımcısı nedir?
05	Seri numarasıyla eşleşen güncel EC Uygunluk Beyanı var mı?

Kaynaklar

- Paylaşılan çalışma örneği: Safety Architecture Doldurma - Lab 3 ve Lab 4. Şişeleme hattına özgü içerik kopyalanmamıştır.
- Biesse kullanım kılavuzu: Rover A 1632 Smart User Manual, 5801A0572, rev. 0, Temmuz 2016, kamuya açık kopya.
- AİMSAD/TWM üye dizini: BIESSE TURKEY Mak. Tic. ve San. A.Ş. kaydı. Üyelik, staj olanağına ilişkin kanıt değildir.

Uygunluk belgesi: Kılavuz makineyle EC Uygunluk Beyanı verildiğini belirtir; erişilebilir kopya belirli makineye seri numarasıyla eşleşen imzalı beyanı içermez. Bu nedenle güncel uygunluk hakkında sonuç çıkarılmamıştır.

Çıktı eşlemesi: Hafta 3 -> EP04 Risk Assessment. Hafta 4 -> EP02 Secure Architecture ve EP06 Remote Access Controls.